BLUEHAMMER

Windows Zero-Day

Threat Hunt & Detection Engineering Guide

Author	Detection Engineering
Date	April 2026
Platform	Microsoft Sentinel + Defender for Endpoint
Threat	**BlueHammer — Unpatched Windows LPE Zero-Day**
Hunt Result	**CLEAN — 8 hunts, environment confirmed clear**
Rules	9 (8 individual + 1 composite correlation)
Patch Status	**UNPATCHED — No CVE as of April 2026**

1. Threat Overview

BlueHammer is a publicly released, unpatched Windows local privilege escalation exploit (public PoC released April 3, 2026). It allows a standard unprivileged user to escalate to NT AUTHORITY\SYSTEM in under 60 seconds with no kernel exploit and no administrative rights required to start.

PATCH STATUS	BlueHammer remains unpatched as of April 2026. No CVE assigned. Microsoft's Defender signature (Exploit:Win32/DfndrPEBluHmr.BB) detects the original PoC binary only — a recompiled variant bypasses it entirely. Behavioral detection is the primary protection layer.

1.1 Exploit Chain

The exploit chains four legitimate, documented Windows components:

Component	Role
Microsoft Defender Update Workflow	Creates a privileged VSS snapshot during remediation — the entry point.
Volume Shadow Copy Service (VSS)	Mounts a snapshot including normally locked SAM, SYSTEM, SECURITY hives.
Cloud Files API (cldapi.dll)	CfRegisterSyncRoot callback gives the attacker a pause button on Defender.
Opportunistic Locks (Oplocks)	Freezes Defender at the exact moment the VSS snapshot is mounted.

1.2 ATT&CK Mapping

Tactic	Technique	Usage in BlueHammer
TA0006 Credential Access	T1003.002	Reads SAM/SYSTEM/SECURITY from VSS snapshot. Decrypts NTLM hashes offline.
TA0006 Credential Access	T1552.002	Reads LSA boot key components (JD/Skew1/GBG/Data) to reconstruct SYSKEY for NTLM decryption.
TA0004 Privilege Escalation	T1068	TOCTOU race: Cloud Files API + oplocks widen the VSS timing gap. RstrtMgr.dll oplock freezes Defender mid-remediation.
TA0005 Defense	T1562.001	Defender selectively frozen via Cloud Files sync root callback that

Tactic	Technique	Usage in BlueHammer
Evasion		identifies Defender by PID.
TA0005 Defense Evasion	T1574.005	NTFS junction + object manager symlink redirects Defender's privileged file read to SAM via VSS.
TA0004 Privilege Escalation	T1134.001	Authenticates as local admin, duplicates token, assigns SYSTEM integrity.
TA0006 Credential Access	T1098	SamiChangePasswordUser resets admin password using NTLM hash, authenticates, then restores hash.
TA0004 / TA0003	T1543.003	Creates GUID-named transient Windows Service to spawn SYSTEM shell in user session.
TA0002 Execution	T1569.002	GUID-named service started as SYSTEM. Spawns conhost.exe in user's interactive session.
TA0040 Impact	T1490	Shadow copy enumeration also covers ransomware pre-deletion of shadow copies.

2. Threat Hunt Methodology

Eight hunt queries were executed covering all primary BlueHammer exploitation indicators. The queries are ordered from highest to lowest confidence. Run them in order — a hit on Hunt 1 or 2 warrants immediate escalation before proceeding.

#	Indicator	Platform	Time Range	Confidence
1	SAM/SYSTEM/SECURITY access via VSS shadow copy path	Advanced Hunting	30 days	Critical
2	Rapid local admin password change + restore (4723/4724)	Sentinel SecurityEvent	7 days	Critical
3	VSS shadow copy enumeration from user-space process	Advanced Hunting	7 days	High
4	cldapi.dll loaded by non-sync process	Advanced Hunting	7 days	High
5	Transient service from non-standard path	Sentinel SecurityEvent	7 days	High
6	SYSTEM shell spawned from services.exe	Advanced Hunting	7 days	High
7	Defender update + VSS enumeration same 5-min window	Advanced Hunting	7 days	Medium
8	Broad SYSTEM shell from non-SYSTEM parent	Advanced Hunting	7 days	Medium

2.1 Hunt Queries

Hunt 1 — SAM/SYSTEM/SECURITY Access via VSS (Advanced Hunting)

```
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has "HarddiskVolumeShadowCopy"
| where FolderPath has_any ("\\Config\\SAM", "\\Config\\SYSTEM", "\\Config\\SECURITY")
| where InitiatingProcessAccountSid != "S-1-5-18"
| where InitiatingProcessAccountName !endswith "$"
| where isnotempty(InitiatingProcessAccountName)
| project Timestamp, DeviceName, InitiatingProcessAccountName,
    InitiatingProcessFileName, InitiatingProcessCommandLine,
    FolderPath, FileName, ActionType
```

Hunt 2 — Rapid Admin Password Change + Restore (Sentinel)

NOTE	TargetDomainName == Computer fails in environments where Computer is stored as FQDN. Use the FQDN-safe filter below.

```
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID in (4723, 4724)
| where TargetUserName has_any ("admin", "administrator")
| where TargetDomainName =~ toupper(tostring(split(Computer, ".")[0]))
| summarize ChangeCount = count(), EventIDs = make_list(EventID),
    FirstEvent = min(TimeGenerated), LastEvent = max(TimeGenerated)
    by TargetUserName, Computer, TargetDomainName
| where ChangeCount >= 2
| extend WindowSeconds = datetime_diff('second', LastEvent, FirstEvent)
| where WindowSeconds < 120
```

Hunt 3 — VSS Enumeration from User Space (Advanced Hunting)

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where ProcessCommandLine has_any (
    "HarddiskVolumeShadowCopy", "Win32_ShadowCopy",
    @"GLOBALROOT\Device\HarddiskVolumeShadow",
    "vssadmin list shadows", "vssadmin list shadowstorage"
)
| where AccountSid != "S-1-5-18"
| where AccountName !endswith "$"
| where FileName !in~ ("wbengine.exe", "vssvc.exe")
| project Timestamp, DeviceName, AccountName, FileName,
    ProcessCommandLine, InitiatingProcessFileName,
    InitiatingProcessCommandLine
```

Hunt 4 — Cloud Files API Abuse (Advanced Hunting)

```
let ApprovedSyncProcesses = dynamic([
    "onedrive.exe", "googledrivefs.exe", "dropbox.exe",
    "boxsync.exe", "svchost.exe", "explorer.exe", "mobsync.exe"
]);
DeviceImageLoadEvents
| where Timestamp > ago(7d)
| where FileName =~ "cldapi.dll"
| where InitiatingProcessAccountSid != "S-1-5-18"
| where InitiatingProcessAccountName !endswith "$"
| where InitiatingProcessFileName !in~ (ApprovedSyncProcesses)
| project Timestamp, DeviceName, InitiatingProcessAccountName,
    InitiatingProcessFileName, InitiatingProcessFolderPath,
    InitiatingProcessCommandLine, InitiatingProcessParentFileName
```

Hunt 5 — Transient Service from Non-Standard Path (Sentinel)

```
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID == 4697
// Note: Key names vary by environment — confirm with: SecurityEvent
// | where EventID == 4697 | project EventData | take 1
| extend ServiceFileName = trim('"',
    tostring(parse_json(EventData).Service_Information_Service_File_Name))
| extend ServiceName = tostring(parse_json(EventData).Service_Information_Service_Name)
| extend SubjectAccount = tostring(parse_json(EventData).SubjectAccountName)
| where SubjectAccount !endswith "$"
| where isnotempty(ServiceFileName)
| where not(ServiceFileName matches regex
    @"(?i)^([A-Z]:\\(Windows|Program\sFiles(\s\(x86\))?|ProgramData|PROGRA~\d)|\\\\?
SystemRoot\\|system32\\)")
| project TimeGenerated, Computer, SubjectAccount, ServiceName, ServiceFileName
```

Hunt 6 — SYSTEM Shell from Service Process (Advanced Hunting)

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe")
| where AccountSid == "S-1-5-18"
| where InitiatingProcessFileName =~ "services.exe"
| where InitiatingProcessCommandLine !has "MpCmdRun"
// LogonId 999 = built-in SYSTEM session (not escalated interactive)
// BlueHammer spawns into an interactive user session with a real LogonId
| project Timestamp, DeviceName, AccountName, FileName,
    ProcessCommandLine, InitiatingProcessCommandLine, LogonId
```

Hunt 7 — Defender Update + VSS Enumeration Same Window (Advanced Hunting)

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName =~ "MpCmdRun.exe"
| where ProcessCommandLine has_any ("SignatureUpdate", "-SignatureUpdate")
| project DeviceName, UpdateTime = Timestamp
| join kind=inner (
    DeviceProcessEvents
    | where Timestamp > ago(7d)
    | where ProcessCommandLine has "HarddiskVolumeShadowCopy"
    | where AccountSid != "S-1-5-18"
    | project DeviceName, VSSScanTime = Timestamp,
        ScanProcess = FileName, ScanAccount = AccountName
) on DeviceName
| where VSSScanTime between (UpdateTime .. UpdateTime + 5m)
| project DeviceName, UpdateTime, VSSScanTime, ScanAccount, ScanProcess
```

Hunt 8 — Broad SYSTEM Shell from Non-SYSTEM Parent (Advanced Hunting)

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where AccountSid == "S-1-5-18"
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe",
    "wscript.exe", "cscript.exe")
| where InitiatingProcessAccountSid != "S-1-5-18"
| where InitiatingProcessFileName !in~ (
    "services.exe", "wininit.exe", "smss.exe", "csrss.exe",
    "lsass.exe", "svchost.exe", "msiexec.exe",
    "trustedinstaller.exe", "tiworker.exe"
)
| project Timestamp, DeviceName, AccountName, FileName,
    ProcessCommandLine, InitiatingProcessAccountName,
    InitiatingProcessFileName, InitiatingProcessCommandLine
```

2.2 Hunt Triage Guide

Result	Action
Hit on Hunt 1 or 2	**Stop. Escalate to IR immediately. Isolate affected host via MDE. Do not continue hunting from an affected machine.**
Hit on Hunt 3, 4, or 5	Escalate to IR. Pull full process tree on affected host. Check for lateral movement before isolating.
Hit on Hunt 6 or 7	Investigate host. Pull 24hr timeline of all process, network, and file events.

Result	Action
	Determine if SYSTEM access was obtained.
Hit on Hunt 8 only	Investigate process tree. Could be BlueHammer or another LPE. Treat as active incident until ruled out.
Clean across all eight	Document hunt with query evidence, time ranges, and result counts. Feed into detection backlog as validated baseline.

3. Detection Rules

Nine rules cover the full BlueHammer kill chain. Eight target individual chain steps. The ninth is a composite correlation rule that fires a single Critical alert when two or more individual indicators appear on the same host within 30 minutes.

DEPLOY ORDER	Individual rules (1-8) must be deployed first. The composite rule (9) queries SecurityAlert which is only populated once individual rules are generating alerts.

#	Rule ID	Severity	ATT&CK	Notes
1	win_security_vss_shadow_copy_enumeration_user_space	High	T1082/ T1068	Step 1. VSS recon. Also covers ransomware shadow copy pre-deletion. 7d back-test clean.
2	win_security_cloud_files_sync_root_untrusted_process	High	T1068/ T1562.001	Step 3. Cloud Files API Defender freeze. DeviceImageLoadEvents required. 7d back-test clean.
3	win_security_vss_registry_hive_shadow_copy_access	Critical	T1003.002	Step 5. Near-definitive. No legitimate FP profile. 30d back-test clean.
4	win_security_lsa_bootkey_registry_access_non_lsass	Critical	T1552.002	Step 5-6. LSA boot key extraction. DeviceRegistryEvents required. [credit: technoherder]
5	win_security_samlib_load_non_lsass_process	High	T1098	Step 6. samlib.dll load by non-LSASS. Pre-event indicator before 4723/4724. [credit: technoherder]
6	win_security_local_admin_password_rapid_change_restore	Critical	T1098/ T1134.001	Step 7. Highest behavioral uniqueness. FQDN-safe query. 7d back-test clean.
7	win_security_service_install_non_standard_path	High	T1543.003	Step 8. Requires env tuning. Regex-based path filtering. 7d back-test clean after tuning.
8	win_security_guid_named_transient_service_creation	High	T1543.003/ T1569.002	Step 8. GUID service name pattern. More specific than Rule 7. [credit: technoherder]

#	Rule ID	Severity	ATT&CK	Notes
9 *	win_security_bluehammer_kill_chain_correlation	Critical	Multi	COMPOSITE — deploy after rules 1-8 are active.

SYSMON / ADVANCED EDR	Three additional detection concepts from technoherder/BlueHammerFix require telemetry not available in standard Sentinel + MDE: RstrtMgr.dll exclusive oplock (Step 2), NTFS junction to \BaseNamedObjects\Restricted (Step 4), and non-Defender RPC to IMpService (Step 4). These require Sysmon EventID 18 (pipe events), kernel file op telemetry, or ETW RPC tracing. See technoherder/BlueHammerFix Sigma rules for implementations.

3.1 Environment Notes for Deployment

- Rule 7 — EventData JSON: Confirm EventData key names for Event ID 4697 in your environment. Run: `SecurityEvent | where EventID == 4697 | project EventData | take 1`. The trim("", ...) call handles environments where ServiceFileName includes surrounding quote characters.
- Rule 6 — FQDN fix: If Computer is stored as an FQDN (HOST.domain.com) and TargetDomainName as NetBIOS (HOST), the standard TargetDomainName == Computer filter fails. The query uses `toupper(tostring(split(Computer, ".")[0]))` — validate this matches your environment.
- Rule 2 — Table availability: Verify DeviceImageLoadEvents is available: `search in (DeviceImageLoadEvents) "*" | take 1`. Enable via Microsoft Defender XDR data connector if not present.
- Rules 4, 5 — Registry telemetry: Verify DeviceRegistryEvents captures LSA key reads: `DeviceRegistryEvents | where RegistryKey has "Control\\Lsa" | take 10`. If no results, adjust MDE configuration or note the coverage gap.
- Rule 7 — Tuning required: This rule will generate FPs until tuned against your software inventory. Run a 7-30 day back-test and populate ApprovedEnterprisePaths and ApprovedServiceNames before production deployment.
- Rule 9 — Entity extraction: HostName extraction from SecurityAlert Entities JSON may need adjustment depending on how your Sentinel serializes entities. Validate during adversary simulation testing.

4. Threat Scenario Chain

The complete BlueHammer kill chain with ATT&CK mapping and detection coverage at each step. Steps 2 and 4 require Sysmon or advanced EDR telemetry — see technoherder/BlueHammerFix for Sigma rule implementations covering those steps.

Step	Technique	Phase	BlueHammer Action	Detection
1	T1082/T1068	Reconnaissance	Enumerate \Device\HarddiskVolumeShadowCopy* in worker thread waiting for Defender update snapshot.	win_security_vss_shadow_copy_enumeration_user_space
2	T1068/ T1562.001	Defender Freeze I	Open RstrtMgr.dll with exclusive batch oplock. Defender hits oplock mid-remediation and stalls while VSS is created.	Sysmon required — see technoherder/BlueHammerFix
3	T1068/ T1562.001	Defender Freeze II	Register Cloud Files sync root with CF_CONNECT_FLAG_REQUIRE_PROCESS_INFO. Identify Defender by PID. Freeze via oplock on .lock placeholder.	win_security_cloud_files_sync_root_untrusted_process
4	T1068/ T1574.005	SAM Redirect	RPC to IMpService. NTFS junction from %TEMP% to \BaseNamedObjects\Restricted. Symlink chain redirects Defender's privileged read to SAM via VSS.	Pipe/kernel events required — see technoherder/BlueHammerFix
5	T1003.002/ T1005	Credential Access	Read SAM/SYSTEM/SECURITY hives from VSS device path. Read LSA boot key components (JD/Skew1/GBG/Data). Decrypt NTLM hashes.	win_security_vss_registry_hive_shadow_copy_access + win_security_lsa_bootkey_registry_access_non_lsass
6	T1003.002/ T1552.002	Hash Decryption	Reconstruct SYSKEY. Load samlib.dll. Call SamiChangePasswordUser with recovered NTLM hash.	win_security_samlib_load_non_lsass_process + win_security_lsa_bootkey_registry_access_non_lsass
7	T1098/ T1134.001	Privilege Escalation	Reset local admin password. Authenticate. Duplicate SYSTEM token. Restore original hash.	win_security_local_admin_password_rapid_change_restore

Step	Technique	Phase	BlueHammer Action	Detection
8	T1543.003/ T1569.002	SYSTEM Shell	Create GUID-named temporary service. Start as SYSTEM. Spawn conhost.exe in user's interactive session. Delete service.	win_security_guid_named_transient_service_creation + win_security_service_install_non_standard_path
9*	Multi	All Phases	2+ indicators fire on same host within 30 minutes.	win_security_bluehammer_kill_chain_correlation (composite)

5. Companion Research

technoherder/BlueHammerFix (https://github.com/technoherder/BlueHammerFix) is essential reading alongside this guide. Their repo provides the red team and static analysis perspective on BlueHammer that complements the blue team detection focus here.

technoherder/ BlueHammerFix	Details
Static analysis	Full 7-stage exploit chain walkthrough across ~3,450 lines of source code.
Bug fixes	9 bugs fixed in the original PoC. --force flag added to bypass Windows Update API check for lab testing.
Lab validation	Stages 1-5 validated in a controlled environment.
Sigma rules	7 vendor-agnostic Sigma rules convertible to any SIEM via sigma-cli or pySigma.
YARA rules	4 rules: exact binary match + 3 variant detection rules.
Lab emulation	Use FunnyApp.exe --force to bypass the pending Defender update prerequisite. Build: VS 2022 + Windows SDK 10.0.26100.0, Release x64.

CREDIT Rules 4, 5, and 8 in this detection set are Sentinel KQL adaptations of Sigma rules from technoherder/BlueHammerFix. All original detection concepts for those rules are theirs. They have been back-tested against production telemetry and FP guidance has been added for Sentinel-specific deployment.

6. Key IOCs

Source: technoherder/BlueHammerFix technical analysis. IOCs are split into structural (reliable across recompiled variants) and volatile (trivially changed with a one-line source edit).

WARNING	Do not rely on volatile IOCs alone. An attacker recompiling from source changes all volatile strings in minutes. Behavioral detections are the durable protection layer.

6.1 Structural IOCs — Reliable Across Variants

IOC	Type	Why It's Stable
RPC UUID c503f532-443a-4c69-8300-ccd1fbdb3839 to IMpService endpoint	Process/RPC	Required interface UUID to call ServerMpUpdateEngineSignature — changing it breaks the exploit.
NTFS junction from %TEMP% to \BaseNamedObjects\Restricted	Filesystem	Fixed Windows kernel object namespace — structural to the junction+symlink technique.
SamiChangePasswordUser import from samlib.dll	Binary/YARA	Undocumented API required for local pass-the-hash. No substitute exists.

6.2 Volatile IOCs — Will Change in Modified Variants

IOC	Type	Why It Changes
Chrome/141.0.0.0 User-Agent from non-browser to go.microsoft.com	Network	Single string — trivial one-line change.
IHATEMICROSOFT as Cloud Files provider name	Memory	Arbitrary string passed to CfRegisterSyncRoot — any value works.
$PWNed666!!!WDFAIL temporary password	Memory	Arbitrary password string — any valid Windows password works.
GUID-named directories in %TEMP% with .vdm files	Filesystem	GUID generated at runtime — staging path is configurable.
%TEMP%\<GUID>\foo.exe EICAR trigger file	Filesystem	Filename and content can be changed — any file Defender scans works.

7. Deployment Checklist

	Task	Done
1	Run all 8 hunt queries against your environment. Document results.	[ ]
2	Run Rule 7 back-test (7-30 days SecurityEvent) and tune ApprovedEnterprisePaths and ApprovedServiceNames for your environment.	[ ]
3	Confirm DeviceImageLoadEvents table is available for Rule 2.	[ ]
4	Confirm DeviceRegistryEvents captures LSA key reads for Rules 4 and 5.	[ ]
5	Validate FQDN fix for Rule 6 in your environment.	[ ]
6	Add custom cloud sync processes for Rule 2 if needed.	[ ]
7	Execute unit tests for all eight individual rules.	[ ]
8	Execute adversary simulation using --force flag (technoherder/BlueHammerFix) in isolated environment. Confirm individual rules fire.	[ ]
9	Deploy individual rules (1-8) to staging. Observe 24-48 hours.	[ ]
10	Deploy individual rules to production.	[ ]
11	Run adversary simulation again — confirm Rule 9 composite fires.	[ ]
12	Validate Rule 9 entity extraction (HostName). Adjust if empty.	[ ]
13	Deploy Rule 9 composite to staging then production.	[ ]
14	Notify SOC with release notes and response guidance for all 9 rules.	[ ]

8. Document Control

Version	Date	Author	Change
1.0	April 2026	Detection Engineering	Public release. Threat hunt (8 queries), ATT&CK mapping, kill chain, 6 detection rules, deployment checklist. All company-specific references removed.
1.1	April 2026	Detection Engineering	Updated to 9 rules. Added 3 KQL adaptations from technoherder/BlueHammerFix Sigma rules (lsa_bootkey, samlib_load, guid_named_service). Kill chain updated to 8

Version	Date	Author	Change
			steps. ATT&CK mapping expanded. Companion research section added. Key IOCs section (structural vs volatile) added. Sysmon dependency notes added.